

ESTRARRE FILE ESEGUIBILE DA PCAP:

Apriamo Wireshark dalla nostra Cyberops Workstation e apriamo il PCAP riguardante il download del file W32.Nimda.Amm.exe (che osserveremo poi essere file rinominato).
e cerchiamo tramite analisi forense se si tratta veramente di file malizioso, cosa possiamo osservare dallo stream TCP di download, e ad estrarre dal PCAP l'eseguibile stesso tramite export di esso come oggetto HTTP.

The screenshot displays the Wireshark network protocol analyzer interface. The top menu bar includes File, Edit, View, Go, Capture, Analyze, Statistics, Telephony, Wireless, Tools, and Help. The main window is divided into three panes: Packet List, Packet Details, and Packet Bytes. The Packet List pane shows a list of captured packets, with packet 4 selected. The Packet Details pane shows the structure of the selected packet, which is an HTTP GET request. The Packet Bytes pane shows the raw data of the selected packet, which is the HTTP request body.

No.	Time	Source	Destination	Protocol	Length	Info
1	0.000000	209.165.200.235	209.165.202.133	TCP	74	48598 → 6666 [SYN] Seq=0 Win=29200 Len=0 MSS=1460 SACK_PERM TSval=4051203246 TSecr=0 WS=512
2	0.000259	209.165.202.133	209.165.200.235	TCP	74	6666 → 48598 [SYN, ACK] Seq=0 Ack=1 Win=28960 Len=0 MSS=1460 SACK_PERM TSval=3023496465 TSecr=4051203246 WS=512
3	0.000297	209.165.200.235	209.165.202.133	TCP	66	48598 → 6666 [ACK] Seq=1 Ack=1 Win=29696 Len=0 TSval=4051203246 TSecr=3023496465
4	0.000565	209.165.200.235	209.165.202.133	HTTP	230	GET /W32.Nimda.Amm.exe HTTP/1.1

The Packet Details pane for the selected packet (No. 4) shows the following structure:

- Frame 4: 230 bytes on wire (1840 bits), 230 bytes captured (1840 bits) on interface 0
- Ethernet II, Src: ea:05:2c:1e:90:3d (ea:05:2c:1e:90:3d), Dst: 16:4c:37:9e:eb:50 (16:4c:37:9e:eb:50)
- Internet Protocol Version 4, Src: 209.165.200.235, Dst: 209.165.202.133
- Transmission Control Protocol, Src Port: 48598, Dst Port: 6666, Seq: 1, Ack: 1, Len: 0
- Hypertext Transfer Protocol

The Packet Bytes pane shows the raw data of the selected packet, which is the HTTP request body:

```

0000 16 4c 37 9e eb 50 ea 05 2c 1e 90 3d 08 00 45 00  L7: P...
0010 00 d8 2f 66 40 00 40 06 d3 fd d1 a5 c8 eb d1 a5  /f0: 0...
0020 ca 85 bd d6 1a 0a ec 07 5b 57 d1 69 5f 03 80 18  .....[W...
0030 00 3a 37 87 00 00 01 01 08 0a f1 78 74 ae b4 36  :7.....xt:6
0040 e5 11 47 45 54 20 2f 57 33 32 2e 4e 69 6d 64 61  GET /W32.Nimda
0050 2e 41 6d 6d 2e 65 78 65 20 48 54 54 50 2f 31 2e  .Amm.exe HTTP/1.
0060 31 0d 0a 55 73 65 72 2d 41 67 65 6e 74 3a 20 57  1:-User-Agent: M
0070 67 65 74 2f 31 2e 31 39 2e 31 20 28 6c 69 6e 75  get/I:19.1 (linu
0080 70 2d 67 6e 75 20 0d 0a 41 63 63 65 70 74 3a 20  e-gnu) -- Accpt:
0090 2a 2f 2a 0d 0a 41 63 63 65 70 74 2d 45 6e 63 6f  // -- Acc ept-Enc
00a0 64 69 6e 67 3a 20 69 64 65 6e 74 69 74 79 0d 0a  ding: id entity:
00b0 48 6f 73 74 3a 20 32 30 39 2e 31 36 35 2e 32 30  Host: 20 9.165.20
00c0 32 2e 31 33 33 3a 36 36 36 0d 0a 43 6f 6e 6e 2.133:66 66--Conn
00d0 65 63 74 69 6f 6e 3a 20 4b 65 65 70 2d 41 6c 69  ection: Keep-All
00e0 76 65 0d 0a 0d 0a 0d 0a 0d 0a 0d 0a 0d 0a 0d  ve....

```

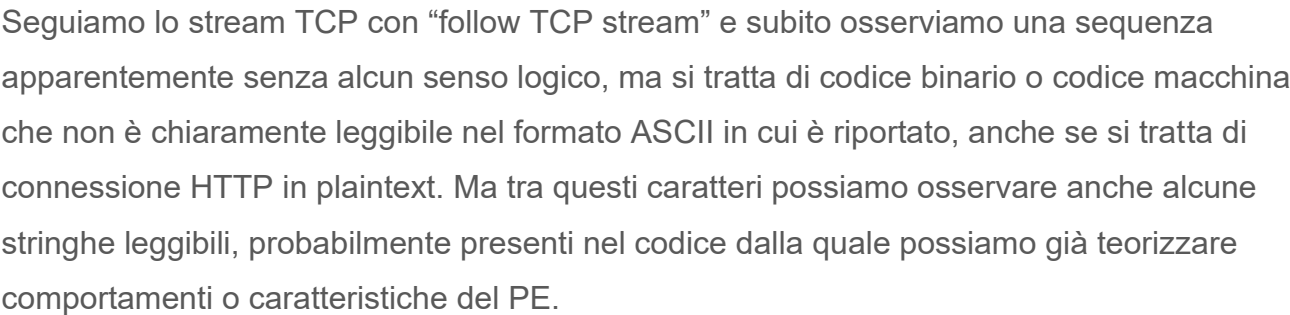
Notiamo subito il three-way-handshake TCP iniziale seguito da una richiesta 'GET' HTTP per il file W32.Nimda.Amm.exe tra IPv4 209.165.200.235 (inizializza connessione) e 209.165.202.133 (server/host che serve il file sospetto, probabile C2 se fosse situazione reale).

1	0.000000	209.165.200.235	209.165.202.133	TCP	74	48598 → 6666 [SYN] Seq=
2	0.000259	209.165.202.133	209.165.200.235	TCP	74	6666 → 48598 [SYN, ACK]
3	0.000297	209.165.200.235	209.165.202.133	TCP	66	48598 → 6666 [ACK] Seq=

Presenza di handshake completo è indicatore che la connessione sia stata stabilita e il trasferimento file compiuto integralmente.

4	0.000565	209.165.200.235	209.165.202.133	HTTP	230	GET /W32.Nimda.Amm.exe HTTP/1.1
---	----------	-----------------	-----------------	------	-----	---------------------------------

da notare l'uso di port 6666 non usuale, chiaro indicatore di attività sospetta.



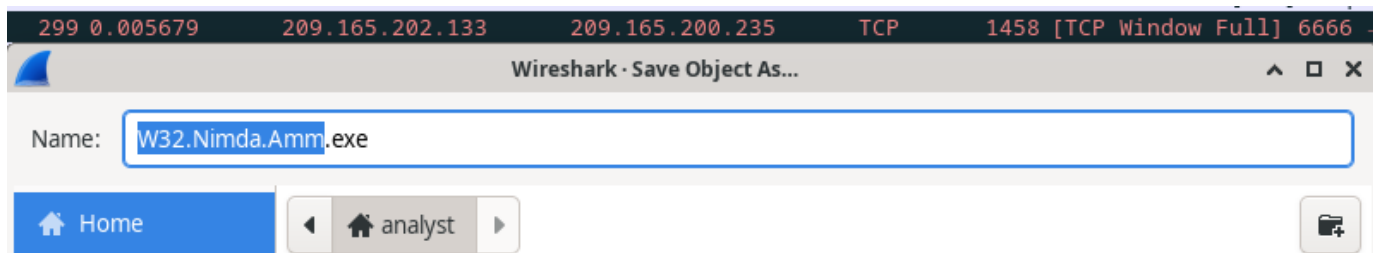
Per motivi di sicurezza si tratta di un eseguibile rinominata anziché un vero sample del malware Nimda. Possiamo notare subito la presenza di una chiamata a `cmd.pdb`, ovvero il program database di `cmd` su Windows. Un'altra prova che si tratta di `cmd.exe` è il riferimento alla registry key propria di `cmd.exe` ovvero `\Microsoft\Command Processor`

Text Filter:

Content Type:

Packet	Hostname	Content Type	Size	Filename
309	209.165.202.133:6666	application/octet-stream	345 kB	W32.Nimda.Amm.exe

Ora estraiamo l'eseguibile con Export http Object su Wireshark. Vediamo in questa HTTP Object list solo il nostro file di interesse W32.Nimda.Amm.exe in quanto è l'unico oggetto HTTP richiesto tramite 'GET' in questa sessione registrata nel PCAP.



Salviamolo su /home/analyst/ e andiamo a controllare alcune informazioni a riguardo.

```

Terminal - analyst@secOps:~
File Edit View Terminal Tabs Help
[analyst@secOps ~]$ pwd
/home/analyst
[analyst@secOps ~]$ ls -l
total 388
-rw-r--r-- 1 root root 5535 May 12 08:26 capture.pcap
-rw-r--r-- 1 root root 5195 May 12 08:29 capture_real.pcap
drwxr-xr-x 2 analyst analyst 4096 Jun 17 2025 Desktop
drwxr-xr-x 3 analyst analyst 4096 Jun 18 2025 Downloads
drwxr-xr-x 9 analyst analyst 4096 Jun 18 2025 lab.support.files
drwxr-xr-x 3 analyst analyst 4096 Jun 18 2025 scripts
drwxr-xr-x 2 analyst analyst 4096 Mar 21 2018 second_drive
-rw-r--r-- 1 analyst analyst 320 May 14 08:59 space.txt
-rw-r--r-- 1 analyst analyst 473 May 14 09:40 testazzo.html
-rw-r--r-- 1 analyst analyst 345088 May 21 07:59 W32.Nimda.Amm.exe
drwxr-xr-x 5 analyst analyst 4096 Jun 18 2025 yay
[analyst@secOps ~]$

```

PE32+ (64bit PE) executable for MS Windows 6.01 (eseguibile per Microsoft Windows 7 / Server 2008) (console) (console application, combacia con la nostra teoria che si tratti di cmd.exe), x86-64 (64bit architecture), 6 sections (6 sezioni standard di PE).

```

[analyst@secOps ~]$ file W32.Nimda.Amm.exe
W32.Nimda.Amm.exe: PE32+ executable for MS Windows 6.01 (console), x86-64, 6 sections
[analyst@secOps ~]$

```

Cosa farebbe ora un analista per verificare il comportamento dell'eseguibile e nel caso rispondere ad un incidente informatico?

- Isolare dispositivo HOST, impedire ulteriori infezioni tramite movimento laterale su rete, investigare dispositivi direttamente esposti per comportamenti anomali, mettere file malware in quarantina, analisi forense network.
- Ottenere file malizioso come abbiamo fatto ad esempio ora, controllare HASH signature su VirusTotal o se presente come report su any.run o altri servizi di vendors sicurezza basati su signature.
- Attraverso sandbox cloud o laboratorio air-gapped per analisi malware fare un analisi statica e dinamica per ricostruire il comportamento del file una volta eseguito ed identificare possibili C2, domini, enumerazioni, movimenti laterali e ulteriori compromissioni che potrebbe aver già causato.
- Determinare meccanismi di persistenza, vale la pena “pulire” il computer vittima o è il caso di fare un’installazione fresca di Windows da flash USB per sicurezza?
- Blacklist su firewall di IP maliziosi, domini, C2 e del file stesso. Scrivere rule di YARA tramite informazioni ricavate da analisi malware e aggiornarle su EDR per evitare altre infezioni da questo specifico malware.

